DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING (CYBERSECURITY)

AMET UNIVERSITY, KANATHUR, CHENNAI

FINAL YEAR PROJECT — PHASE I / FIRST REVIEW

Attack Path Risk Engine

An Extension of Cartography for Automated Multi-Hop Attack Path Discovery and Risk-Based Prioritisation in Cloud Environments

1. Project Title

Attack Path Risk Engine: An Extension of Cartography for Automated Multi-Hop Cloud Attack Path Discovery and Risk-Based Prioritisation.

2. Team Details

S.no	Name	Register No.	Department
1	Kithiyon	ACS23003	CSE (Cybersecurity)
2	Mohamed Abdul Baasid	ACS23004	CSE (Cybersecurity)
3	Rahsheetha	ACS23007	CSE (Cybersecurity)

3. Problem Statement

Cartography builds a graph of cloud assets, identities, and permissions, but there is no automated way to (a) discover multi-hop attack paths from exposed entry points to sensitive targets, (b) score each path's relative risk, or (c) present findings without manual graph-query expertise. Most real-world cloud breaches arise not from one dramatic flaw but from a chain of ordinary, low-severity misconfigurations. This project addresses all three gaps.

4. Project Abstract

Cloud security incidents rarely come from a single flaw — they arise from chains of ordinary misconfigurations linking an exposed asset to sensitive data. Cartography, a CNCF open-source tool, already collects inventory from 30+ platforms into a Neo4j graph and names attack-path discovery as a goal, but today that discovery is entirely manual, requiring hand-written Cypher queries. This project builds the Attack Path Risk Engine on top of that graph: a depth-bounded traversal that automatically finds paths from exposed entry points to sensitive targets, a 0–100 risk-scoring model based on impact, hop count, privilege type gained, and any mitigating controls present; and a dashboard that reports ranked findings in plain, actionable language. Validation uses a seeded AWS sandbox, since no public benchmark of labelled cloud attack paths exists. Cartography's own source code stays unmodified; all new work is a separate, clearly attributed module under its Apache 2.0 licence. Phase I (~40% completion) delivers path-discovery and risk-scoring; Phase II (~60%) delivers the dashboard, integration, and final validation.

5. Objectives

1. To study Cartography's architecture and data schema to identify where new functionality can be added without modifying its source code.
2. To implement a path-discovery module that traverses the infrastructure graph from entry points to sensitive targets within a bounded depth.
3. To design a quantitative risk-scoring model that ranks paths by severity, based on recognised cloud attack-path concepts.
4. To build a web dashboard that presents ranked findings in plain language for a security reviewer.
5. To validate the system against realistic misconfiguration scenarios in a controlled sandbox environment.

6. Domain Identification

Primary domain: Cybersecurity.

Sub-domains: Cloud Security, Cloud Infrastructure Security, and Attack Path Analysis — at the intersection of graph-based security analytics and cloud IAM.

7. Literature Survey

Eleven recent papers (IEEE, ACM, USENIX, Springer, Elsevier, Wiley, arXiv) were reviewed, focused on cloud IAM privilege escalation, attack-path generation, and attack-graph scalability — the areas most relevant to this project.

#	Paper	Author(s)	Venue / Year	Relevance
1	Multi-target Risk Score Aggregation for Security Evaluation of Network Environments	M. Lei et al.	IEEE CloudCom, 2024	Pairwise path-based score aggregation across a network — directly informs the project's scoring-formula design.
2	Fixing Privilege Escalations in Cloud Access	Y. Hu et al.	IEEE/ACM ASE, 2023	Automated detection and remediation of IAM

#	Paper	Author(s)	Venue / Year	Relevance
	Control with MaxSAT and Graph Neural Networks (IAMPERE)			privilege-escalation chains in cloud graphs.
3	SkyEye: When Your Vision Reaches Beyond IAM Boundary Scope in AWS Cloud	M. H. Nguyen, A. M. Ho, and B. S. To	arXiv, 2025	Cross-principal AWS IAM enumeration — relevant to entry-point and privilege-boundary identification.
4	CloudLens: Modeling and Detecting Cloud Security Vulnerabilities	M. Kazdagli, M. Tiwari, and A. Kumar	arXiv, 2024	Formal relational model of cloud IAM plus a planner that generates attacks to find vulnerabilities — closely related modelling approach.
5	BRIDG-ICS: AI-Grounded Knowledge Graphs for Intelligent Threat Analytics in Industry 5.0 Cyber-Physical Systems	P. Nandiya et al.	Springer (Cybersecurity, open access), 2026	Neo4j Graph Data Science attack-path analysis using Yen's k-shortest-path and Dijkstra's algorithm — methodologically close to the project's path-discovery layer.
6	Behind the Scenes of Attack Graphs: Vulnerable Network Generator for In-Depth Experimental Evaluation of Attack Graph Scalability	A. Palma and S. Bonomi	Computers & Security (Elsevier), 2025	Addresses attack-graph scalability and synthetic dataset generation — informs the project's sandbox-validation approach.

8. Research Gap / Existing-System Gap

- Cartography and similar tools build a queryable graph of infrastructure, identities, and permissions, but none automate multi-hop attack-path search — a security engineer must hand-write a Cypher query for every question.
- IAM privilege-escalation detectors such as IAMPERE [2] detect individual escalation types well but aren't built on a general-purpose, multi-platform infrastructure graph.

- Risk-scoring approaches such as [1] aggregate scores across a network but don't factor mitigating controls (e.g., MFA) into cloud IAM privilege-transition chains.
- No public, labelled benchmark of real-world cloud attack paths exists, a limitation shared across this field — addressed here through a documented sandbox validation methodology.

9. Proposed Solution

The Attack Path Risk Engine adds three layers on top of Cartography's graph, without modifying its source code: a path-discovery layer performing depth-bounded traversal from entry points to sensitive targets; a risk-scoring layer assigning each path a 0–100 score based on impact, path length, privilege-transition type, and mitigating controls; and a React dashboard reporting ranked findings in plain language. Together these convert Cartography's graph into a prioritised, automated list of an attacker's most viable routes.

10. Innovation / Novelty

The novelty lies in combining three properties, each present individually in prior work but not previously combined on a general-purpose, multi-platform infrastructure graph: (1) fully automated multi-hop path discovery rather than manual querying; (2) a documented, explainable risk-scoring formula that rewards real mitigating controls such as MFA rather than target sensitivity alone; and (3) implementation as a clean, separately attributed extension of Cartography, leaving its own code untouched.

11. Methodology

11.1 Path Discovery

A Python module queries Cartography's Neo4j graph, starting from nodes flagged as exposed or vulnerable, and runs a depth-bounded BFS with pruning to find paths reaching sensitive targets (data stores, admin roles, secrets managers).

11.2 Risk Scoring

Each path is scored as Risk Score = Impact(target) × Likelihood(path) × 10, where Likelihood(path) = DecayFactor(hops) × HopWeightProduct × MitigationMultiplier (derivation and worked examples in Section 11.3).

11.3 Worked Example

Formula and worked example

```
Risk Score = Impact(target) × Likelihood(path) × 10
Likelihood(path) = 0.85^(hops-1) × HopWeightProduct ×
MitigationMultiplier

Example — Public EC2 → AssumeRole (no MFA) → Production S3
Bucket (Impact = 9), 2 hops:
Likelihood = 0.85 × 0.9 × 1.0 = 0.765  →  Risk Score = 9 ×
0.765 × 10 = 68.9  (HIGH)

Example — Public EC2 → PolicyAttachment (MFA present) →
Administrative Role (Impact = 8), 2 hops:
Likelihood = 0.85 × 0.7 × 0.5 = 0.2975  →  Risk Score = 8 ×
0.2975 × 10 = 23.8  (MEDIUM/LOW)
```

The second path targets a higher-privilege resource but scores lower because a real mitigating control (MFA) is present — demonstrating that the model rewards genuine security controls rather than ranking purely on target sensitivity.

11.4 Presentation

A React dashboard shows ranked paths as plain-language findings (e.g., "Public Web Server → Admin Role → Production S3 Bucket — Risk: HIGH"), with a node-by-node graph view of the selected path.

12. System Architecture

The system adds three new layers on top of Cartography's existing graph, as shown below.

Layer 3 — Presentation (New contribution — Technology: React)

React dashboard showing ranked attack paths in plain, actionable language.
e.g. "Public Web Server → Admin Role → Production Database — Risk: HIGH"

▲ data flows upward ▲

Layer 2 — Risk Scoring (New contribution — Technology: Python)

Scores every discovered path by path length, privilege gained per hop, and mitigations present.
Risk Score = Impact(target) × Likelihood(path) × 10 (see Section 11.3)

▲ data flows upward ▲

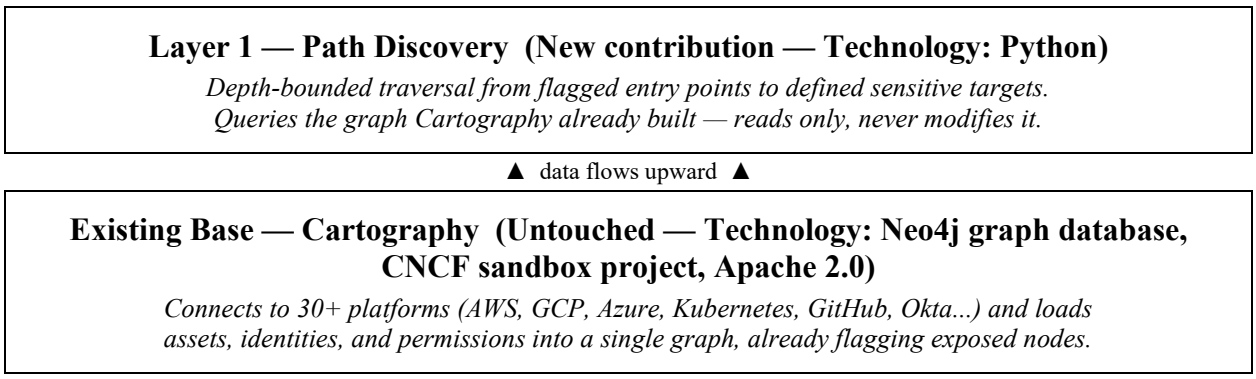


Figure 1. System architecture — Path Discovery, Risk Scoring, and Presentation layers built on Cartography's existing graph.

13. Hardware & Software Requirements

Component	Requirement
Base project	Cartography (Python, Apache 2.0 licence)
Graph database	Neo4j
Path discovery & scoring engine	Python 3.x
Dashboard	React
Cloud sandbox environment	AWS (free tier / student credits)
Development hardware	Standard development laptop; no GPU required
Version control	Git / GitHub

14. Dataset / Data Source

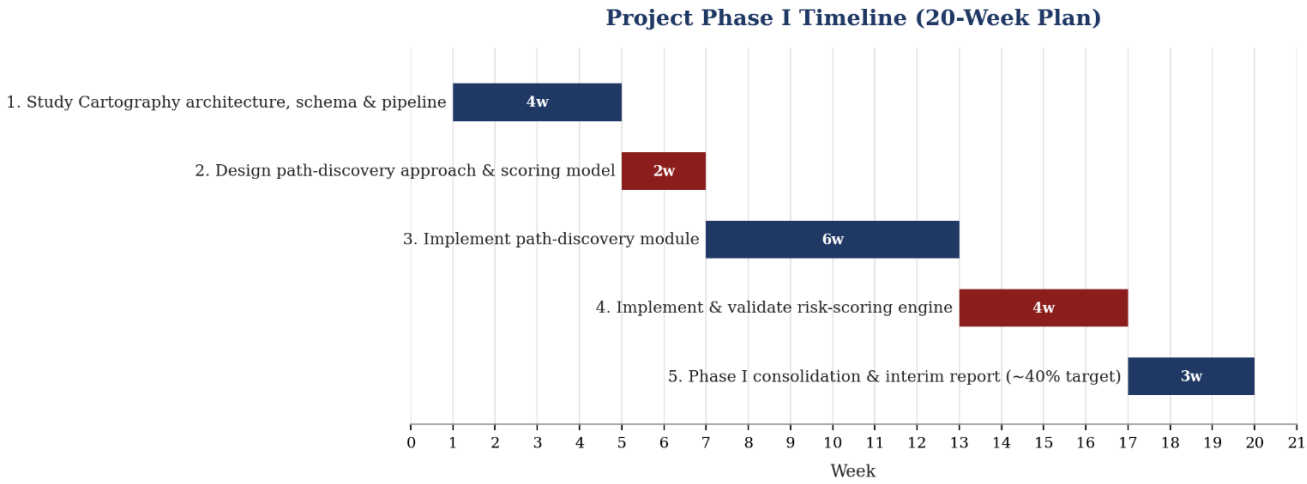
No public, labelled benchmark of real-world cloud attack paths exists (Section 7), so data is generated from a dedicated AWS sandbox account populated with representative misconfigurations (an exposed EC2 instance, an over-permissive IAM role, a production-like S3 bucket, and a secrets store). Cartography's existing, unmodified connectors pull this sandbox's inventory into the Neo4j graph the system operates on.

15. Expected Outcome

- Phase I (~40%): a working path-discovery module and validated risk-scoring engine, both on a live Cartography graph.
- Phase II (~60%): a usable web dashboard, full integration of all three layers, and validation against sandbox scenarios.
- A documented, justified risk-scoring model with worked validation scenarios.
- A final report and viva in which every design decision can be independently explained by each team member.

16. Project Timeline

The project spans the full academic year in two phases. Phase I (Aug–Dec 2026, ~40%) covers study, design, path discovery, and risk scoring. Phase II (Jan–May 2027, ~60%) covers the dashboard, integration, testing, and documentation.



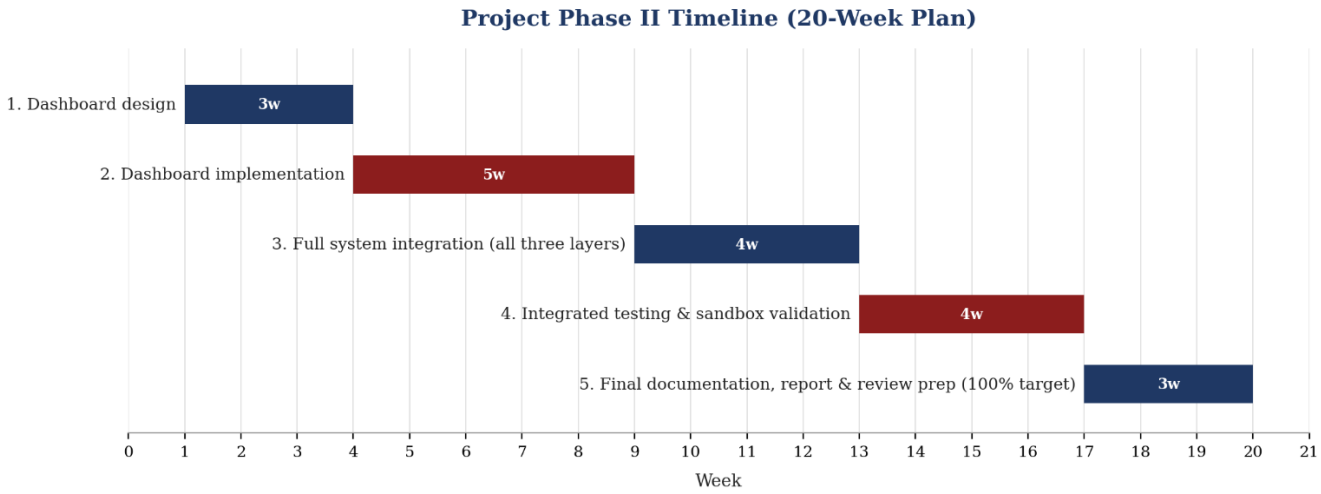


Figure 2. Full academic-year timeline — Phase I (Aug–Dec 2026) and Phase II (Jan–May 2027).

17. Work Distribution

Team Member	Primary Responsibility
Mohamed Abdul Baasid	Path discovery module; Cartography schema and intel-module study; graph query design
Rahsheetha	Risk-scoring model design, validation scenarios, and documentation of scoring justification
Kithiyon	Dashboard design and implementation; integration with backend outputs

All three members jointly study Cartography's core architecture before specialising, and co-author the design document, so each can explain the full system during evaluation.

18. References

[1] M. Lei, T. A. Madi, M. Nitschke, L. Zhao, and M. Pourzandi, "Multi-target Risk Score Aggregation for Security Evaluation of Network Environments," in Proc. 2024 IEEE Int. Conf. on Cloud Computing Technology and Science (CloudCom), 2024, pp. 71–78.

[2] Y. Hu, W. Wang, S. Khurshid, K. L. McMillan, and M. Tiwari, "Fixing Privilege Escalations in Cloud Access Control with MaxSAT and Graph Neural Networks," in Proc. 2023 38th IEEE/ACM Int. Conf. on Automated Software Engineering (ASE), 2023, doi: 10.1109/ASE56229.2023.00167.

[3] M. H. Nguyen, A. M. Ho, and B. S. To, "SkyEye: When Your Vision Reaches Beyond IAM Boundary Scope in AWS Cloud," arXiv:2507.21094, 2025.

[4] M. Kazdagli, M. Tiwari, and A. Kumar, "CloudLens: Modeling and Detecting Cloud Security Vulnerabilities," arXiv:2402.10985, 2024.

[5] P. Nandiya, A. Mohsin, A. Ibrahim, I. H. Sarker, and H. Janicke, "BRIDG-ICS: AI-Grounded Knowledge Graphs for Intelligent Threat Analytics in Industry 5.0 Cyber-Physical Systems," Cybersecurity (Springer, open access), 2026.

[6] A. Palma and S. Bonomi, "Behind the Scenes of Attack Graphs: Vulnerable Network Generator for In-Depth Experimental Evaluation of Attack Graph Scalability," Computers & Security, vol. 157, art. 104576, Oct. 2025.